

System Specific Policy for Network Router Protection from Ransomware

Semir Hot, Harrison Maksimik

March 10, 2024

Contents

1	Statement of Policy	1
1.1	Purpose	1
1.2	Scope	1
1.3	Responsibilities	1
2	Technical Specifications	2
2.1	Subnets	2
2.2	Access control	2
2.3	Authentication	3
3	Scheduled Reviews	3

1 Statement of Policy

1.1 Purpose

The purpose of this policy is to create a set of guidelines for the implementation of security systems on our organization’s network router. The network router serves as a gateway for attack to other systems on our organization’s network, and ensuring that proper hardening measures are taken on the router will reduce the likelihood of attack on more critical systems. Thus, the goal of this document is to describe three security measures that should be implemented on any network routers added to our organization.

1.2 Scope

This policy applies to all network routers used in our Phillips 66 branch. Any system administrator or contractor responsible for configuring and maintaining network router hardware and software should have read, understood, and follow the guidelines listed in this document.

1.3 Responsibilities

It should be the responsibility of the CISO to respond to new business needs not considered in this document, and keep to this document up-to-date. System administrators, contractors and other qualified personnel, along with third-party workers, should be responsible for the implementation of the listed security measures. All other employees and workers should be responsible for following the spirit of this document; it should not be acceptable to circumvent the security controls implemented as described in this document. Should new business needs conflict with these controls, a notice containing relevant details should be sent as soon as possible to the employee's line manager, other information security personnel, or the CISO via email.

2 Technical Specifications

2.1 Subnets

Our organization should ensure that the network routers used can facilitate the creation of several subnets in order to contain ransomware and other malware infections into only small portions of the network. Subnets which contain more critical assets should have stronger firewall settings, as described in the system-specific policy for firewalls. Subnets should be created for each individual information system, and an additional subnet should be made for employee devices. As of the current iteration of this document, the following subnets should be created:

- CCTV/DVR subnet
- Office Computer subnet
- Backup Servers subnet
- POS System subnet (Modisoft)
- Employee Devices/Wireless Access subnet

2.2 Access control

Our organization's network contains several systems, each of which should be accessed by different communities of interest. In order to facilitate both confidentiality and accessibility, as well as to prevent the spread of ransomware and other malware outside of the systems of the infected community of interest, a strong access control policy should be implemented for all network shared devices and data. The specific implementation details of this access control model are defined more in the issue-specific policy on ransomware, and a separate system-specific policy.

2.3 Authentication

In order to ensure the integrity of the software and configuration of the network router, our organization must mandate the use of strong passwords and authentication strategies for all users with access to the router. If unauthorized users attain access to the control panel of the router, all other network-based security controls can be disabled, leading to a high risk of ransomware or other malware infection in the system, as well as loss of CIA. The specific requirements for password complexity should be described by a separate system-specific policy for password creation, as password requirement change frequently.

3 Scheduled Reviews

This policy should be reviewed by the CISO and other parties of interest on an annual basis. New technologies may make the current security controls obsolete in the future; each of the provided guidelines under the *Security Controls* section should be carefully reviewed during this time.